

Incident Report Analysis

Simulated scenario

Summary	At approximately 10:00 AM this morning, an employee noticed an anomaly in the internal network's performance; the network was running unusually slowly. She immediately alerted the security team. A review of the network logs confirmed an unusually high volume of network traffic at the time of the report. The employee stated that at approximately 9:00 AM, she had received an email asking her to visit an external website and log in using her internal network credentials in order to retrieve a message. We believe this is the method used by a malicious actor to gain unauthorized access to our network and customer database. This is consistent with a phishing attack designed to harvest employee credentials. A separate employee reported that some customer data had been manipulated, while other records had disappeared from the system entirely, as confirmed by a preliminary database review. This incident is currently under investigation to determine the full scope of the systems and data affected.
Identify	The incident management team audited the systems, devices, and access policies involved in the attack to identify gaps in security. The team determined that an intern's login credentials were obtained by a malicious actor through a phishing email and used to access the customer database. Upon initial review, it appears that some customer records were altered or deleted. Identity and access: MFA will be required for all users with access to sensitive data, and access rights will follow the principle of least privilege, so that limited-scope roles (such as interns) cannot reach the full customer database. Network: the internal network will be segmented to isolate systems that store or process sensitive data, and the firewall will be updated to filter inbound traffic. Because the high traffic volume was likely caused by unauthorized data access or exfiltration using valid credentials, rate-based blocking is a secondary control and does not address the root vector. Email security: an email filtering solution will be deployed to block phishing messages and suspicious external links. Awareness: staff will receive regular security awareness training, including periodic phishing simulations, to improve recognition of social engineering.

Protect	Identity and access: MFA will be required for all users with access to sensitive data, and access rights will follow the principle of least privilege, so that limited-scope roles (such as interns) cannot reach the full customer database. Network: the internal network will be segmented to isolate systems that store or process sensitive data, and the firewall will be updated to filter inbound traffic. Because the high traffic volume was likely caused by unauthorized data access or exfiltration using valid credentials, rate-based blocking is a secondary control and does not address the root vector. Email security: an email filtering solution will be deployed to block phishing messages and suspicious external links. Awareness: staff will receive regular security awareness training, including periodic phishing simulations, to improve recognition of social engineering.
Detect	To detect unauthorized access attempts in the future, the team will centralize firewall and system logs in a SIEM to correlate events and generate alerts; deploy an IDS/IPS and monitor both inbound and outbound traffic to spot possible data exfiltration; configure alerts for anomalous logins (unusual hours, unexpected geolocation, failed attempts followed by a success); enable audit logging and integrity monitoring on the customer database to flag mass queries, modifications, and deletions.
Respond	Immediately after the incident was detected, the team disabled the network account of the affected employee and isolated the account's access to the customer database. Other potentially exposed accounts were reviewed and their credentials reset as a precaution. Relevant logs and evidence were preserved for forensic analysis before any remediation changes were made. Management was informed within the first 24 hours. Awareness meetings and training sessions were organized to explain how to protect credentials. Affected customers were notified by email. Legal authorities and regulators were notified as required by applicable law, such as the LGPD (Brazil, with notification to

	the ANPD), the GDPR (EU, generally within 72 hours to the supervisory authority), and the Swiss nLPD (notification to the FDPIC as soon as possible).
Recover	The team will recover the affected data in the following order: 1. Confirm containment: verify that the attacker no longer has access and that all compromised credentials have been reset. 2. Validate the backup: verify that last night's full backup is intact and was taken before the compromise. 3. Restore the database from that backup. Where available, apply point-in-time recovery using transaction logs, to reduce the loss of legitimate data entered during the morning. 4. Verify data integrity by comparing restored records against logs and, if necessary, re-entering any data that could not be recovered. 5. Resume services gradually and monitor closely. Staff have been informed that any information entered or changed this morning and not recoverable will need to be re-entered manually. A post-incident review will document lessons learned and update the response plan (RC.RP, ID.IM).

Reflections / Notes:

This incident shows how a single compromised credential can escalate into a data integrity problem when technical safeguards are missing. The phishing email was the entry point, but the impact was amplified by the absence of MFA, excessive privileges on an intern account, no network segmentation, and no automated detection.

Two areas stand out for improvement. First, access should be reviewed against the principle of least privilege. Second, the phishing email was received at about 9:00 AM and the anomaly was reported at about 10:00 AM, so the attacker had at most one hour of undetected activity. Real-time alerting on anomalous behavior would reduce dwell time more effectively than relying on employee reports.

The Respond actions were comprehensive (containment, credential resets, notifications), although the actual containment time should be measured to evaluate effectiveness. Going forward, I would prioritize MFA and phishing simulations, since they address the entry point, together with least privilege to limit the impact of any future compromise.

Under NIST CSF 2.0, this case also highlights the **Govern** function: clear policies for access management, defined roles and responsibilities, and regular risk reviews would have reduced the likelihood of this incident.